

UNIVERSITÀ DEGLI STUDI DI SALERNO

Penetration Testing

Anno accademico 2025/2026

Hack the Box: Orion

Pentest Report

Professore

Prof. Arcangelo Castiglione

Studente

Eljon Hida
Mat: 0522501890

Contents

1	Executive Summary	2
2	Engagement Highlights	2
3	Vulnerability Report	3
4	Remediation Report	4
5	Findings Summary	4
6	Detailed Summary	5
6.1	Vulnerabilità Critical	6
6.2	Vulnerabilità Low	7
6.3	Vulnerabilità Info	7
	Bibliografia	9

1 Executive Summary

Come caso di studio su cui applicare il processo di Penetration Testing è stato scelto Orion, macchina vulnerabile by design di Hack The Box. Gli obiettivi principali da raggiungere sono:

1. Enumerazione dei servizi e individuazione delle vulnerabilità a loro associate;
2. Accesso alla macchina target;
3. Prendere possesso della flag per l'account root;
4. Cercare di instanziare una backdoor.

Il processo di penetration testing ha avuto inizio il 22/08/2026 ed è stato condotto secondo un approccio di tipo Grey Box. Infatti, al momento dell'avvio erano infatti già note alcune informazioni relative al target, in particolare l'indirizzo IP della macchina e il sistema operativo utilizzato, mentre non erano disponibili informazioni preliminari sui servizi attivi e sulla loro configurazione.

L'attività è stata inoltre svolta secondo un approccio White Hat, con l'obiettivo di identificare e verificare eventuali vulnerabilità presenti nel sistema, documentarne i risultati e valutarne i possibili impatti. Per ciascuna vulnerabilità individuata sono state inoltre considerate, ove possibile, opportune soluzioni volte a mitigarne il rischio.

2 Engagement Highlights

Il progetto è stato svolto con finalità esclusivamente didattiche e, pertanto, non ha previsto alcuna interazione con un cliente reale né la definizione di specifici requisiti di assessment da parte di un'organizzazione esterna.

L'attività di penetration testing è stata strutturata seguendo la metodologia e le principali fasi operative illustrate durante il corso. Sono stati pertanto utilizzati gli strumenti e le tecniche presentati durante le lezioni, applicandoli progressivamente alle diverse fasi dell'analisi:

- **Information Gathering & Target Discovery:** raccolta delle informazioni iniziali relative al target e individuazione della superficie di attacco;
- **Target Enumeration & Port Scanning:** identificazione dei servizi esposti, delle porte aperte e delle tecnologie utilizzate dal sistema;
- **Vulnerability Mapping:** individuazione e correlazione delle potenziali vulnerabilità associate ai servizi e alle componenti rilevate;
- **Target Exploitation:** verifica dell'effettiva sfruttabilità delle vulnerabilità individuate attraverso tecniche di exploit;

- **Post-Exploitation - Privilege Escalation:** analisi delle possibilità di incremento dei privilegi ottenuti sul sistema compromesso;
- **Post-Exploitation - Maintaining Access:** valutazione delle tecniche utilizzabili per mantenere l'accesso al sistema oltre la fase iniziale di compromissione.

Più nel dettaglio, per ognuna di queste fasi gli strumenti utilizzati sono stati:

Fase	Strumento	Note
Information Gathering & Target Discovery	ping, nmap, p0f	N/A
Target Enumeration & Port Scanning	nmap, masscan, dirb	N/A
Vulnerability Mapping	Ricerca manuale con NVD, Nessus, Nikto2	N/A
Target Exploitation	Meterpreter, Metasploit, approccio manuale	N/A
Privilege Escalation	Meterpreter, Hashcat	N/A
Maintaining Access	Metasploit	N/A

Table 1: Strumenti utilizzati nelle diverse fasi del pentest

3 Vulnerability Report

Durante l'analisi della macchina Orion sono emerse vulnerabilità effettivamente improtanti, più nel dettaglio:

- Presenza di una vulnerabilità nel CMS utilizzato che permette ad un attaccante non autenticato di eseguire codice arbitrario sul server remoto;
- Presenza di una vulnerabilità nel servizio Telnet che permette di bypassare il processo di autenticazione e ottenere un accesso con privilegi di root;
- Presenza di una configurazione del servizio ICMP che permette di ottenere informazioni relative al timestamp del sistema remoto, facilitando potenzialmente attività di fingerprinting;
- Utilizzo di versioni non aggiornate dei servizi esposti, che possono rendere la macchina vulnerabile ad attacchi già documentati e aumentare la superficie di attacco.

4 Remediation Report

La macchina Orion presenta un grado di rischio elevato, principalmente a causa della presenza di vulnerabilità critiche nei servizi esposti. Per mitigare i rischi individuati è possibile adottare le seguenti contromisure:

- Effettuare l'aggiornamento di Craft CMS alla versione 5.6.17 o successive;
- Aggiornare il pacchetto Inetutils a una versione corretta, oppure disabilitare il servizio Telnet qualora non sia strettamente necessario;
- Limitare le richieste ICMP Timestamp mediante opportune regole di filtraggio sul firewall, consentendo esclusivamente il traffico ICMP strettamente necessario;
- Disabilitare i servizi non necessari o non utilizzati, riducendo così la superficie di attacco della macchina;
- Mantenere costantemente aggiornati il sistema operativo, i servizi e le applicazioni utilizzate, applicando tempestivamente le patch di sicurezza disponibili.

5 Findings Summary

Durante l'attività di penetration testing sono state identificate diverse vulnerabilità e condizioni di sicurezza rilevanti. I risultati ottenuti sono stati classificati in cinque categorie in base al livello di gravità:

- **Critical:** vulnerabilità con un impatto critico sulla sicurezza del sistema;
- **High:** vulnerabilità con un elevato livello di rischio e un potenziale impatto significativo;
- **Medium:** vulnerabilità con un livello di rischio moderato;
- **Low:** vulnerabilità con un impatto limitato sulla sicurezza del sistema;
- **Info:** informazioni e rilevamenti tecnici che non rappresentano direttamente una vulnerabilità.

La distribuzione dei findings nelle diverse categorie di gravità fornisce una visione complessiva del livello di esposizione del sistema analizzato:

Critical	High	Medium	Low	Info	Totale	
2	0	0	1	11	14	no.Vulnerabilità

Table 2: Numero Vulnerabilità e Classificazione

Per una visualizzazione più immediata e intuitiva, il seguente grafico a barre mostra la distribuzione in base al livello di gravità:

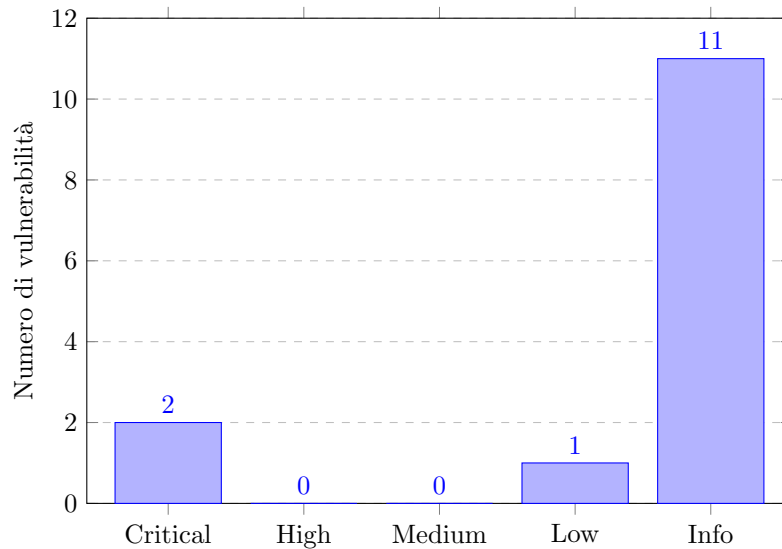


Figure 1: Distribuzione delle vulnerabilità per livello di gravità

Tra i risultati mostrati non sono presenti quelli ottenuti con la scansione di Nikto2, poiché l'unica vulnerabilità rilevante individuata è la CVE-2000-0413. Tale vulnerabilità, tuttavia, non è applicabile alla macchina Orion, in quanto interessa le Microsoft FrontPage Server Extensions, nello specifico il componente shtml.exe presente su sistemi Microsoft IIS 4.0/5.0. Nel caso in esame, l'enumerazione del target ha invece evidenziato l'utilizzo di nginx 1.18.0 su Ubuntu come web server. Non è pertanto presente la componente software interessata dalla CVE.

6 Detailed Summary

Questa sezione elenca tutte le vulnerabilità individuate sia con approccio manuale che con gli strumenti utilizzati (Nessus). Nel caso di vulnerabilità individuata manualmente sulla scheda sarà presente il flag **M** (manuale), altrimenti **A** (automatico)

6.1 Vulnerabilità Critical

CVE-2025-32432 [1]	$\geq 3.0.0\text{-RC1}, < 3.9.15$ $\geq 4.0.0\text{-RC1}, < 4.14.15$ $\geq 5.0.0\text{-RC1}, < 5.6.17$
Descrizione: La versione di Craft CMS usata per la creazione e gestione di Orion è la 5.6.16. È una vulnerabilità critica di Remote Code Execution (RCE) in Craft CMS che consente a un attaccante non autenticato di eseguire codice arbitrario sul server remoto tramite richieste appositamente manipolate. È disponibile un exploit fornito da Cyberdefense [2] che spiega nel dettaglio sul come creare la richiesta POST.	
Mitigazione: Fare upgrade o downgrade di Craft CMS alla versione 3.9.15, 4.14.15 o 5.6.17.	
M	

CVE-2026-24061 [3]	$1.9.3 \leq 2.7$
Descrizione: La versione del servizio telnet presente su Orion è la 2.7. È una vulnerabilità critica di authentication bypass presente nel servizio telnetd. A causa di una gestione non corretta della variabile d'ambiente USER, un attaccante remoto non autenticato può manipolare gli argomenti passati al processo di login e ottenere un accesso con privilegi root. È disponibile un exploit fornito da GreyNoiseLABS [4] che spiega nel dettaglio come è stata individuata la vulnerabilità e come sfruttarla.	
Mitigazione: Aggiornare Inetutils a una versione corretta o disabilitare il servizio Telnet.	
M	

6.2 Vulnerabilità Low

CVE-1999-0524 [5]	ICMP Timestamp Request Information Disclosure
Descrizione: Questa vulnerabilità riguarda il servizio ICMP Timestamp, che può rispondere a richieste ICMP Timestamp provenienti da host remoti. La risposta può consentire a un attaccante di ottenere informazioni sul timestamp del sistema remoto, fornendo indicazioni sull'orologio del dispositivo e potenzialmente facilitando attività di fingerprinting.	
Mitigazione: Applicare regole di filtraggio che consentano esclusivamente il traffico ICMP strettamente necessario.	
A	

6.3 Vulnerabilità Info

-	SSH Protocol Versions
Descrizione: Possibili patch di sicurezza backportate nel server SSH, non riflesse nel numero di versione. È possibile rilevare le versioni del protocollo SSH supportate dal server remoto.	
A	

-	HTTP Information
Descrizione: È possibile risalire a diverse informazioni sulla configurazione del protocollo HTTP.	
A	

-	SYN scanner
Descrizione: È possibile determinare le porte TCP aperte.	
A	

-	SSH SHA-1 HMAC Algorithms Enabled
Descrizione: Il server remoto SSH è configurato per utilizzare l'algoritmo SHA-1 HMAC.	
A	

-	SSH Password Authentication Accepted
Descrizione: Il server SSH sull'host remoto accetta l'autenticazione via password.	
A	

-	Service Detection
Descrizione: È possibile identificare il servizio remoto tramite il banner o i messaggi di errore restituiti in risposta a richieste HTTP.	
A	

-	Common Platform Enumeration
Descrizione: È possibile identificare i prodotti hardware e software presenti sul sistema tramite i relativi CPE (Common Platform Enumeration).	
A	

-	OS Security Patch Assessment Not Available
Descrizione: Non è stato possibile effettuare la valutazione delle patch di sicurezza del sistema operativo remoto.	
A	

-	Traceroute Information
Descrizione: È possibile determinare il percorso di rete tra il sistema di scansione e l'host remoto tramite traceroute.	
A	

References

- [1] National Institute of Standards and Technology, “CVE-2025-32432,” National Vulnerability Database, [Online]. [Online]. Available: <https://nvd.nist.gov/vuln/detail/cve-2025-32432>
- [2] Cyberdefense, “Investigating an in-the-wild campaign using RCE in CraftCMS,” Blog, [Online]. [Online]. Available: <https://sensepost.com/blog/2025/investigating-an-in-the-wild-campaign-using-rce-in-craftcms/>
- [3] National Institute of Standards and Technology, “CVE-2026-24061,” National Vulnerability Database, [Online]. [Online]. Available: <https://nvd.nist.gov/vuln/detail/cve-2026-24061>
- [4] GreyNoiseLABS, “-f Around and Find Out: 18 Hours of Unsolicited Telnet Houseguests,” Blog, [Online]. [Online]. Available: <https://www.labs.greynoise.io/grimoire/2026-01-22-f-around-and-find-out-18-hours-of-unsolicited-houseguests/index.html>
- [5] National Institute of Standards and Technology, “CVE-1999-0524,” National Vulnerability Database, [Online]. [Online]. Available: <https://nvd.nist.gov/vuln/detail/cve-1999-0524>